第二课：NotesApp 建模作业

2026-10-09 · 代码版本 1c83e42 · 简版

学生查看自己的成绩；教师查看、导出和修改成绩；管理员管理用户并使用 Ping。浏览器先请求 Flask，再由 Flask 访问 PostgreSQL。

用课程示例账号做了 24 项正常访问检查，全部通过。数据库为 35 用户、4 班级、60 条成绩。教师导出班级 1 得到 16 行，全量导出得到 60 行。写入表单只观察页面和源码，没有提交。

TB1：浏览器与 Flask。TB2：Flask 与 PostgreSQL。TB3：Web 容器与外部 Ping 目标。本次 Ping 容器自己的 127.0.0.1，没有越过 TB3。

图按功能合并同方向的数据流，共 28 条逻辑箭头。学生页和详情 API 合为一组，新增与更新成绩合为一组。跳转后的读取另走对应的页面流程。

S：示例密码较容易猜；会话密钥固定；API 的 JWT 接受 alg=none，所以有冒用身份的风险。

T：教师写成绩时只检查角色，没有检查是否是自己的班级；页面也没有转义评语。

R：修改成绩有一条简单日志，但没有旧值和新值；创建/删除用户、读取及导出没有对应的业务审计。

I：API 不检查成绩归属；教师页和 CSV 没有按班级归属限制。学生密码、评语在数据库中明文保存。

D：代码没有请求限速；Ping 同步运行，单次最多等待 10 秒。大量请求可能拖慢服务，未做压测。

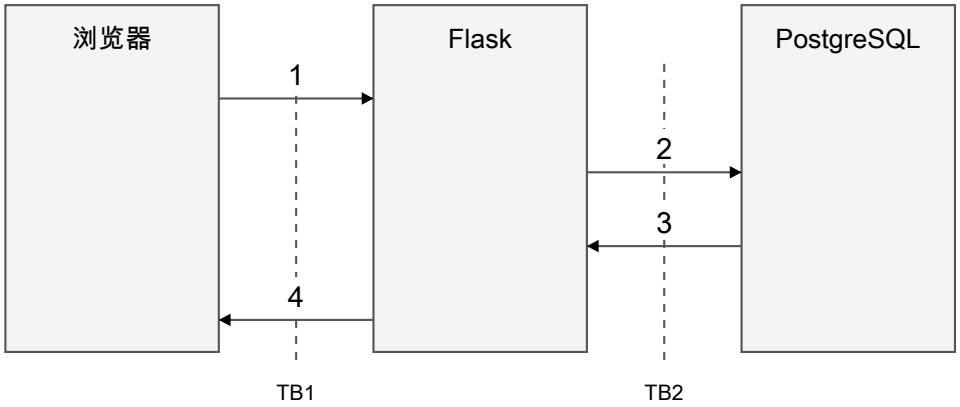
E：Ping 的 host 拼接进 shell 命令，存在命令注入风险；Web 为 root，并挂载 Docker socket，可能扩大后果。

威胁是源码分析得到的可能性，未执行攻击。JWT 不会自动变成管理员会话；CSRF 取决于 Cookie/浏览器行为；HTTP 传输攻击需要接触传输路径。

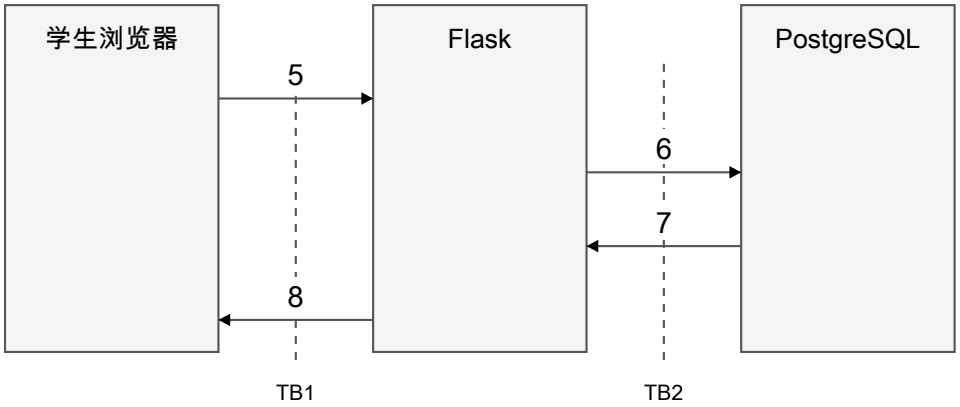
编号数据流图 1/2

每条箭头的消息见下一部分；编号与 STRIDE 表对应。

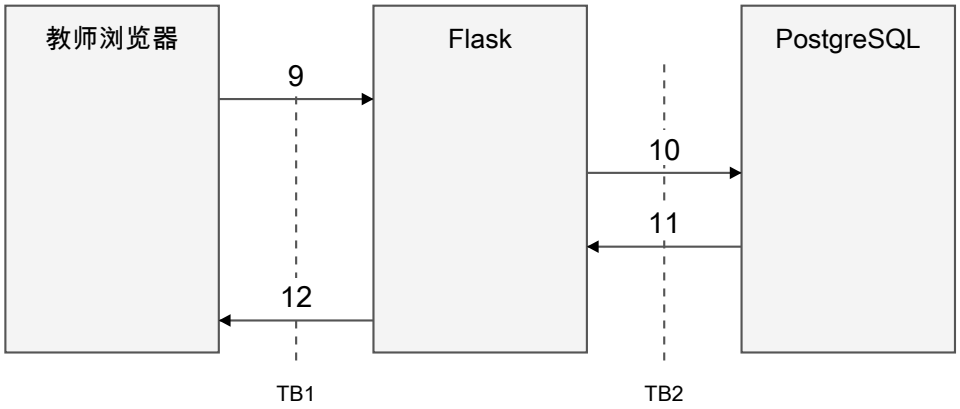
登录



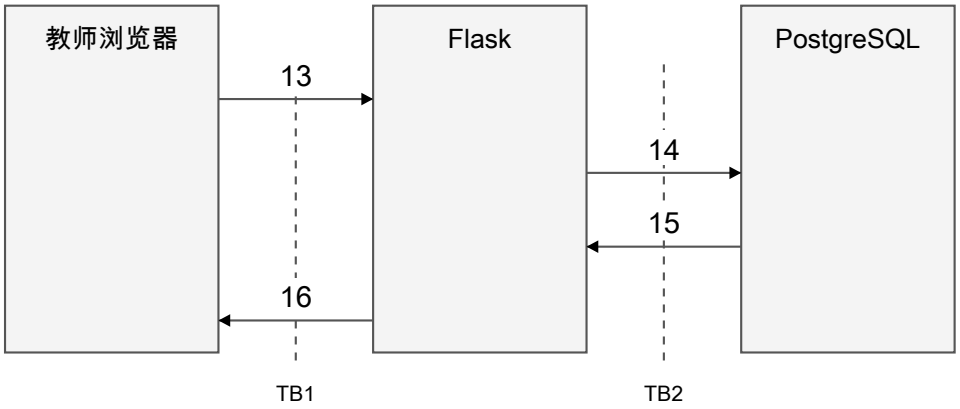
学生查看成绩



教师查看与导出



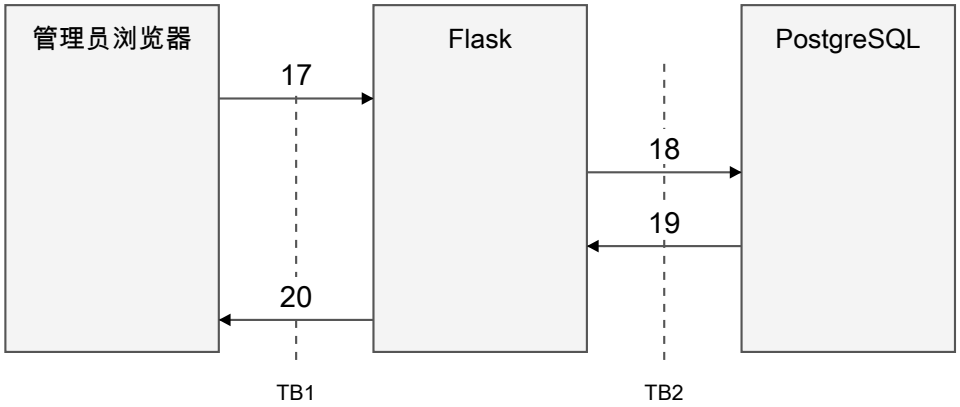
教师新增与修改成绩



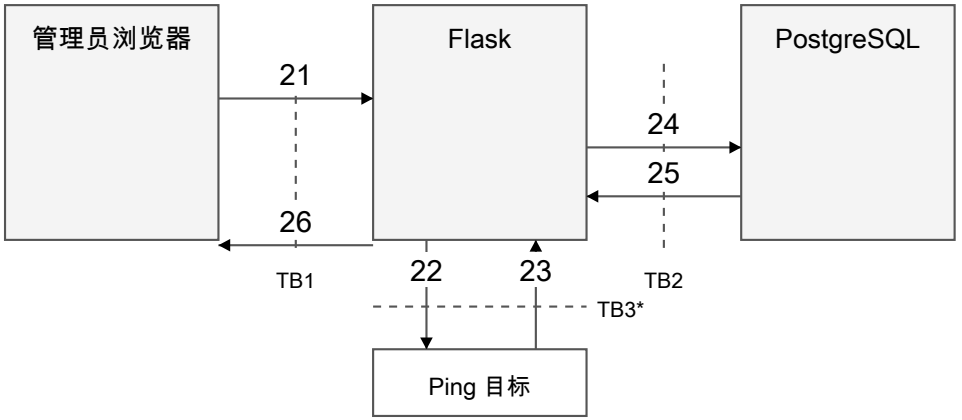
编号数据流图 2/2

每条箭头的消息见下一部分；编号与 STRIDE 表对应。

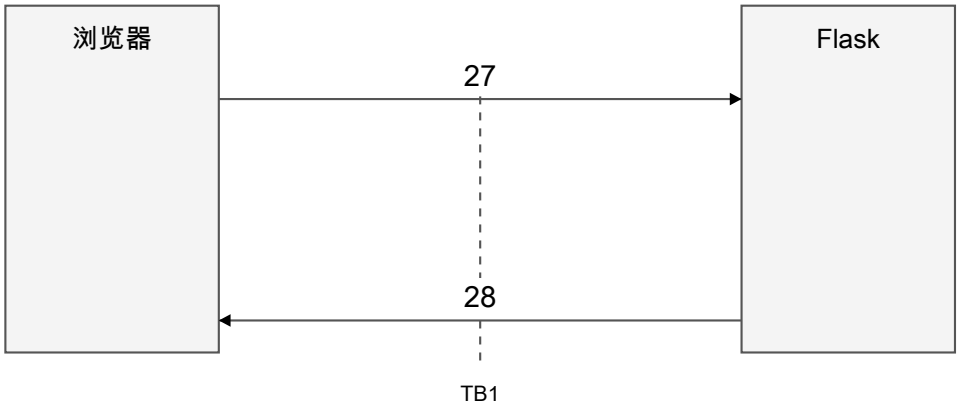
管理员管理用户



管理员 Ping



退出登录



Flow List

编号	发送方 → 接收方	数据	边界
1	浏览器 → Flask	登录：用户名和密码	TB1
2	Flask → PostgreSQL	查询用户账号	TB2
3	PostgreSQL → Flask	返回账号 ID、用户名、角色	TB2
4	Flask → 浏览器	登录结果、会话 Cookie 和跳转	TB1
5	学生浏览器 → Flask	查看成绩页或单条成绩详情	TB1
6	Flask → PostgreSQL	按学生 ID 或成绩 ID 查询成绩	TB2
7	PostgreSQL → Flask	返回成绩、课程和评语	TB2
8	Flask → 学生浏览器	成绩页面 HTML 或详情 JSON	TB1
9	教师浏览器 → Flask	查看教师页或导出 CSV	TB1
10	Flask → PostgreSQL	查询班级、学生和成绩	TB2
11	PostgreSQL → Flask	返回查询结果	TB2
12	Flask → 教师浏览器	返回教师页面或 CSV 文件	TB1
13	教师浏览器 → Flask	新增/更新成绩：ID、成绩、评语	TB1
14	Flask → PostgreSQL	INSERT 或 UPDATE 成绩和评语	TB2
15	PostgreSQL → Flask	返回写入完成状态	TB2
16	Flask → 教师浏览器	跳转到教师页	TB1
17	管理员浏览器 → Flask	查看列表、创建用户或删除用户	TB1
18	Flask → PostgreSQL	查询/插入/删除 users，查询 classes	TB2
19	PostgreSQL → Flask	返回用户/班级数据或执行状态	TB2
20	Flask → 管理员浏览器	返回管理页或跳转到管理页	TB1
21	管理员浏览器 → Flask	提交 Ping 的 host	TB1
22	Flask → Ping 目标	发出 ICMP Echo Request	TB3*
23	Ping 目标 → Flask	收到 ICMP Echo Reply	TB3*
24	Flask → PostgreSQL	查询用户和班级列表	TB2
25	PostgreSQL → Flask	返回用户和班级列表	TB2
26	Flask → 管理员浏览器	返回 Ping 结果和管理页	TB1
27	浏览器 → Flask	退出登录	TB1
28	Flask → 浏览器	清除会话并跳转到登录页	TB1

首版 STRIDE 表

S 冒充 · T 篡改 · R 否认 · I 泄露 · D 拒绝服务 · E 越权。— 表示未发现该流的直接威胁。

流	S	T	R	I	D	E
1	冒用账号	改登录输入	登录日志较简单	HTTP 泄露密码	反复请求登录	SQL 注入绕过登录
2	冒用账号查询	拼接 SQL 可被改变	缺少查询审计	数据库连接未加密	数据库连接耗尽	匹配到其他角色
3	取决于登录查询	取决于登录查询	缺少查询审计	账号数据明文传输	数据库压力	返回错误的身份
4	会话可能被伪造	HTTP 响应可被改	日志证明不完整	Cookie/错误信息泄露	大量登录响应	使用伪造角色
5	伪造会话或 JWT	修改成绩 ID	无读取审计	读取别人记录	大量 API 请求	API 对象越权
6	依赖请求身份	—	无读取审计	API 查询不校验归属	数据库压力	API 对象越权
7	—	已有恶意评语	无读取审计	返回其他学生数据	数据库压力	—
8	—	评语可能含脚本	无读取审计	成绩/评语泄露	大量请求	脚本影响浏览器
9	伪造教师会话	修改班级 ID	无导出审计	读取其他班级	大量导出请求	班级权限越界
10	依赖教师会话	—	无读取审计	查询未按教师筛选	数据库压力	班级权限越界
11	—	已有恶意评语	无读取审计	返回全班级成绩	返回数据过多	—
12	—	页面评语可能含脚本	无导出审计	成绩导出范围过大	内存/响应压力	脚本影响浏览器
13	伪造教师会话	改别人班级成绩	日志缺少修改前后值	HTTP 暴露提交内容	反复提交写入	越过班级权限
14	依赖教师会话	未核对班级归属	修改证据不完整	评语明文存储	数据库压力	越过班级权限
15	—	—	缺少完整修改记录	—	数据库压力	—
16	—	HTTP 响应可被改	不能完整证明修改	Cookie 可能泄露	—	—
17	伪造管理员会话	写入表单缺少 CSRF 检查	用户变更无业务日志	HTTP 泄露新增密码	大量管理请求	伪造管理员权限
18	依赖管理员会话	未经本人确认的变更	用户变更无业务日志	用户密码明文保存	数据库压力	依赖管理员鉴权
19	—	—	无用户变更审计	返回管理数据（无密码）	数据库压力	—
20	—	HTTP 响应可被改	无用户变更审计	用户列表可能泄露	—	—
21	伪造管理员会话	host 拼进 shell 命令	Ping 日志较简单	HTTP 暴露输入	同步 Ping 占用资源	命令注入风险
22	—	—	日志证明不完整	暴露探测目标	Ping 等待占用资源	—
23	—	—	日志证明不完整	—	不回复导致等待	—
24	依赖管理员会话	—	无读取审计	数据库连接未加密	数据库压力	—
25	—	—	无读取审计	管理数据明文传输	数据库压力	—
26	—	HTTP 响应可被改	日志证明不完整	输出可能泄露信息	Ping 阻塞请求	—
27	—	—	没有退出日志	Cookie 可能泄露	—	—
28	已保存 JWT 不会被撤销	HTTP 响应可被改	没有退出日志	—	—	—

代码依据：web/app.py、templates、Dockerfile、Compose、db/init.sql。本地完成，未提交或推送；原草稿保留。